PROMETHEUS · MENTOR REVIEW

OCS Intelligence LLM Open Issues Report

Every open issue from the October 14 deep audit — security, configuration, code, and process — with the evidence, the charts, and the fix order. Prepared for the team ahead of the in-person walkthrough.

Team: Open Coding Society, Del Norte High School (Poway USD)
Mentor: Eddie Revollo, Prometheus · **Teacher:** John Mortensen
Audit date: October 14, 2026 · **Scope:** repository + full git history, gateway & orchestrator code, infra configs, executed test suites, live service probes

SNAPSHOT

Where the project stands

Thirty-two actionable findings from a full audit — and a service that is simultaneously up and down.

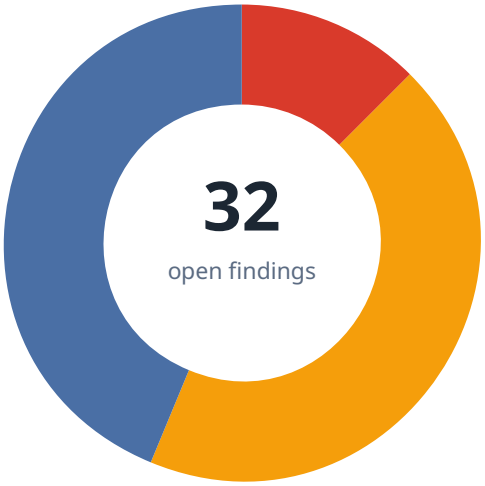
4
High findings — fix first

26
days since the status page was last verified

14
days of silence — no commits, evidence, or reports

16 / 16
offline tests pass (audit re-ran them)

Findings by severity



- High — **4**
- Medium — **14**
- Low — **14**

+ 5 informational / positive notes

Live service health — checked October 14, 2026

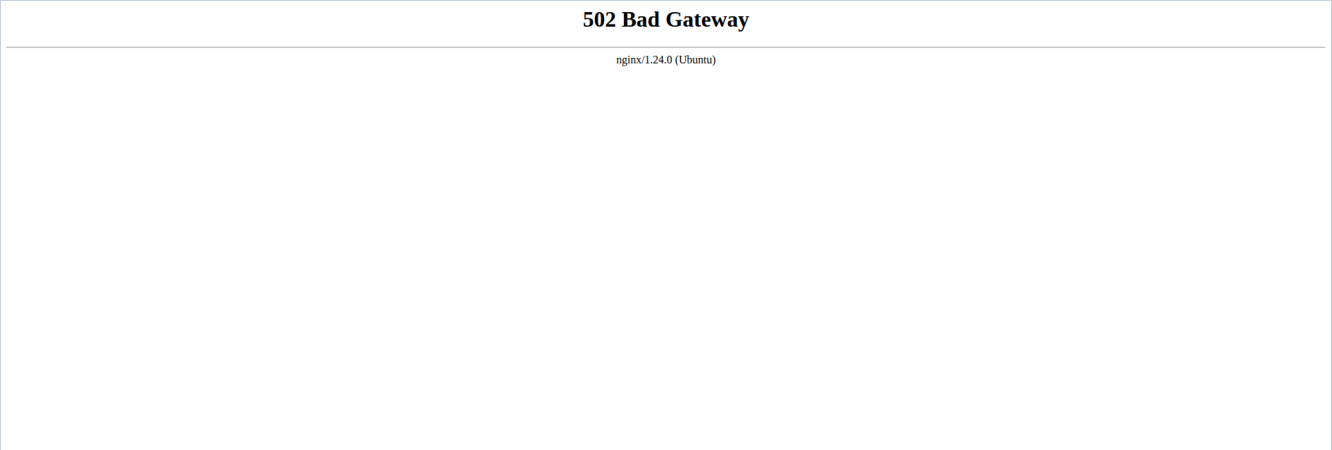
COMPONENT	STATE	EVIDENCE
API gateway (EC2)	UP	Correct 401 auth response on /v1 — the admission path works end-to-end
Orchestrator + workers (rig)	UP	Reached through the gateway path; NetBird link alive
Web interface (Open WebUI)	DOWN	502 Bad Gateway at ai.opencodingsociety.com
Status page (docs/status.md)	STALE	Claims WebUI running; last verified Sep 18 — 26 days ago

The one-sentence version: the engineering core is sound and honestly measured — the operations around it (monitoring, process, records) are what broke.

ISSUE AREA 1 · OPERATIONS

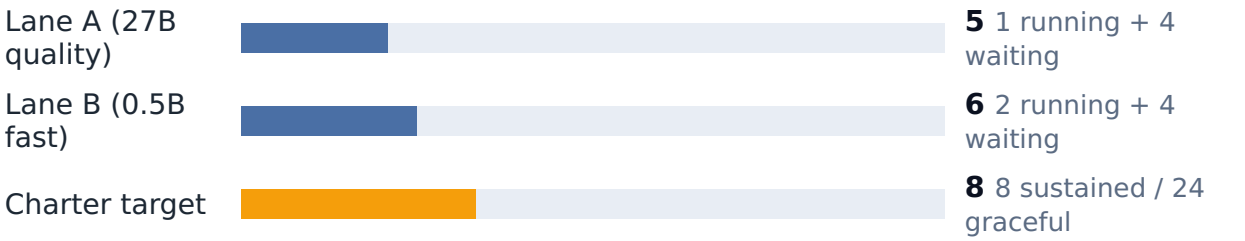
The outage, and the numbers underneath it

Why the front end is down, what capacity the service really has, and the one performance regression still open.



Root cause (most likely): the web interface runs as a hand-started container with **no service definition, no restart policy, and no monitoring** anywhere in the repo (Finding M1). When it stopped — or the rig rebooted and every managed service came back without it — nothing restarted it and nobody was alerted. The stopped Ollama instance is ruled out: it degrades chat inside the interface, it cannot produce a proxy-level 502.

Real capacity vs. the charter's targets



Total system: 3 generations running + 8 waiting = 11 seats, against a charter target of 8 sustained — concurrency targets cannot be met until the load tests actually run.

Open defect: Worker A speed regression

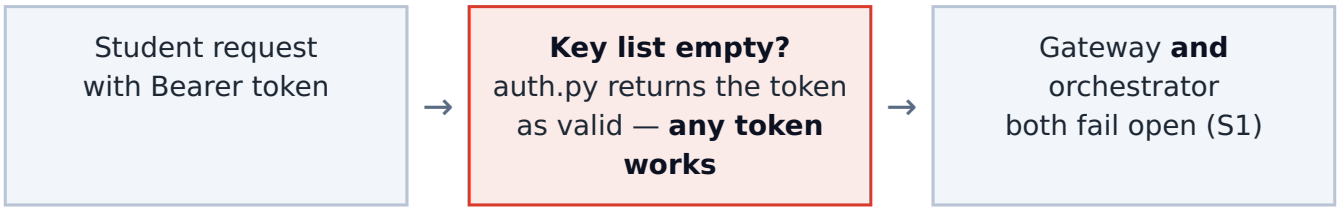


The flagship 27B model runs **30% slower** than the setup it replaced, with no decision date. At 8.7 tok/s, long answers dominate the single Lane A slot — whose timeout is one full hour.

ISSUE AREA 2 · SECURITY

Access control that defaults to off

Two High findings, both about the same theme: the doors are well built, but they open the wrong way when something is missing.



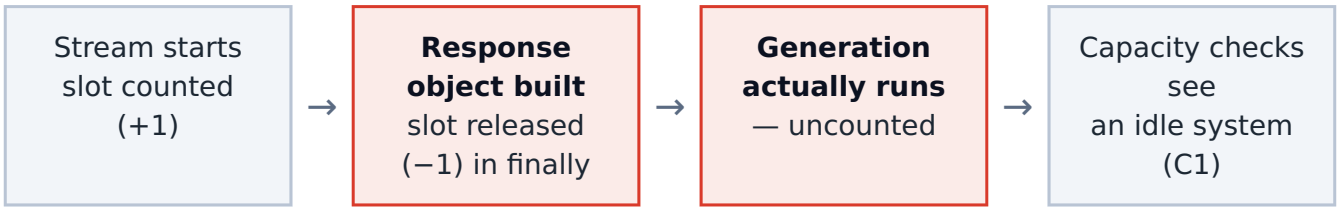
SEV	OPEN ISSUE	WHY IT MATTERS
HIGH	**S1 — Auth fails open on both tiers.** Empty key list = every token accepted (gateway/auth.py, orchestrator/auth.py).	One config mistake = fully open service
HIGH	**S2 — Orchestrator reachable by any network peer.** Binds 0.0.0.0:9000, no firewall rule (their threat model lists it open).	The fair queue and all limits are bypassable
MED	**S3 — One shared student key.** No per-student keys, quotas, or revocation.	A leak exposes everyone; no attribution
MED	**S5 — All services run as root** on both hosts; operators SSH as root (S6).	Any code flaw is a full-host compromise
MED	**S4 — Key comparison is not constant-time** in either service.	Textbook timing side channel; one-line fix
LOW	**S7/S8/S10 —** No rate limiting beyond the lanes; internal IPs & GPU IDs published in the public repo; unbounded request bodies on the orchestrator's direct path.	Queue-saturation denial of service; free reconnaissance

Credit: a full scan of the tree and all 30 commits found **zero real secrets ever committed** — every key value is a placeholder, and .env is properly ignored. The team's secret hygiene is exemplary; these findings are design defaults, not carelessness.

ISSUE AREA 3 · CODE & CONFIGURATION

A queue that can't count streams

One real concurrency bug, a documentation gate nobody runs, and a system that can't be rebuilt the same way twice.



- **C1 (Medium, bug):** for streamed replies — the main mode — the orchestrator releases its in-flight slot when the response object is constructed, before generation runs. Capacity enforcement is effectively void for streaming.
- **C6 (Medium):** the team's own docs checker fails on main — **10 broken links** left by the Sep 29 restructure. Nothing runs it (see D1).
- **C3/C4 (Low):** malformed JSON returns 500 instead of 400 in both services; a latent semaphore over-release sits in the lane code.
- **Coverage gap:** the 16 passing tests cover lanes and benchmark math only — **zero tests on auth, routing, or health**, the security-critical code.

Version reality: the rig runs below its own floors

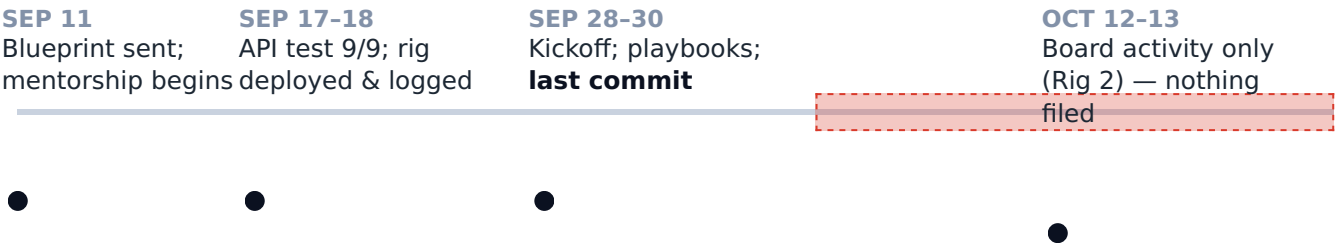


Same story for uvicorn (rig 0.27.1 vs floor 0.30) and httpx (0.26.0 vs 0.27) — the rig's offline package mirror froze it in the past (M2). Dependencies everywhere are unpinned ranges with **no lockfile**, and llama.cpp itself was built from an unpinned master (M4/M5): a redeploy today is a different system than September's. Proxy config also lacks baseline protections — no HSTS or security headers, server version disclosed (M3).

ISSUE AREA 4 · PROCESS & EVIDENCE

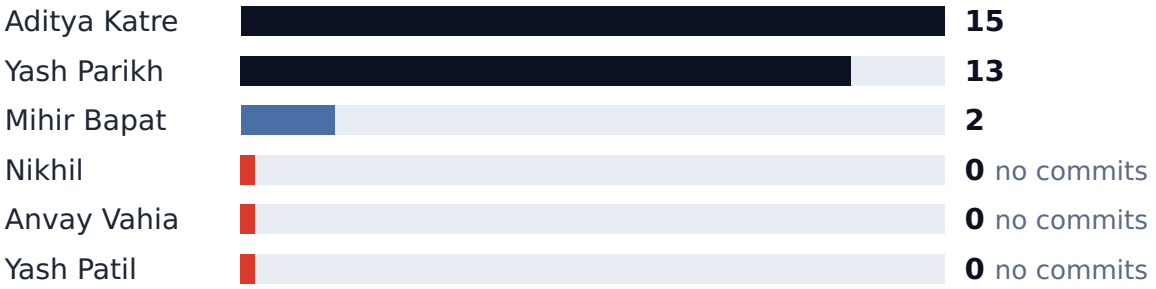
The record stopped; the work didn't

The charter grades this project on handoff. Right now the handoff trail ends on September 30.



The dashed band is the silence: **Oct 1–14** — no commits, no evidence entries, no Friday reports, while work continued off-record.

Who has actually built it — commits by author (30 total)



- **D1 (High): no CI exists at all** — no workflow directory in the repo. Tests and the docs checker run only when remembered. The board's "CI in progress" has not landed.
- **D2 (Medium): zero pull requests, ever.** All 30 commits went straight to an unprotected main — no review step, even for authentication code.
- **D3/D4 (Medium): bus factor of two; evidence folder frozen.** The charter requires a one-page Friday report in evidence/weekly/ — that folder was never created.

Verification the charter promised — status

TEST	STATUS	TEST	STATUS
API end-to-end (Sep 17)	DONE 9/9	Quality test set (≥70% target)	NOT BUILT
Gateway concurrency	DONE	Failure drills (5 kinds)	0 RUN
Sustained load, 8 users	NOT RUN	Per-student keys	NOT DONE
Soak, 4 hours	NOT RUN	Continuity / handoff drill	NOT RUN

REMEDIATION

The fix order

Sequenced for the walkthrough and the road to Night at the Museum. The team proposes; this is the mentor's recommended order.

Now — before the walkthrough

- **Bring the interface back, and put it under management:** a real service definition with a restart policy, plus a basic uptime check that would have caught this outage in minutes, not weeks.
- **Fail closed:** empty key list must reject everything, on both tiers (S1). Add the first pull request and the first CI run while you're at it (D1/D2).
- **Restore the record:** file the missing weekly reports and the Week 2–3 playbooks (D4).

Next — this cycle

- **Firewall the orchestrator** to the gateway only (S2); issue per-student keys with quotas and revocation (S3).
- **Fix the streaming slot bug** (C1) and add the first auth/routing tests.
- **Pin the world:** lockfiles for every service; decide the Worker A speed question — fix NCCL or formally accept 8.7 tok/s, with a date.

Before the showcase

- **Run the promised proofs:** 8-user sustained load, the soak, the quality test set, and at least the capacity and component-loss drills.
- **Run the continuity drill:** a teammate who didn't build it restores the service from the runbook alone. That is the handoff this project is graded on.
- **Refresh the status page** — and keep it honest weekly. A status page that cries healthy is worse than none.

> **The story worth pitching:** real students built a real service, measured it honestly, found it broken, and fixed it in the open. That story — told with these numbers — is the showcase.

Full audit with file-and-line evidence: AUDIT-REPORT (repository review, October 14, 2026). Findings verified against the public repo at HEAD (last push Sep 30, 2026) and live probes on Oct 14, 2026. Server-side state (rig/EC2) could not be inspected directly; outage root cause is stated as most-likely from configuration evidence.